3.7. OWASP Top 10

3. Сети, базы данных,
безопасность кода

В этом уроке

- Познакомимся с основными уязвимостями для веб-приложений
- Разберемся как их эксплуатируют
- Узнаем как от них защититься

Что такое OWASP?

OWASP — Open Web Application Security Project

Не зависит от компаний, цель — обучение и защита

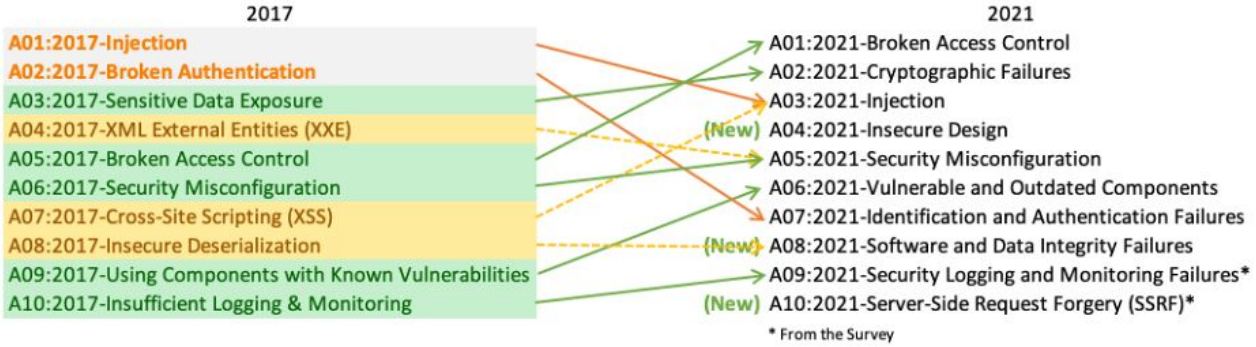
Публикует список 10 самых опасных уязвимостей веб-приложений

Мы разберем OWASP Top 10 + защиту форм

Что такое OWASP?

1. A01: Broken Access Control
2. A02: Cryptographic Failures
3. A03: Injection (SQL, OS, LDAP...)
4. A04: Insecure Design
5. A05: Security Misconfiguration
6. A06: Vulnerable and Outdated Components
7. A07: Identification and Authentication Failures
8. A08: Software and Data Integrity Failures
9. A09: Security Logging and Monitoring Failures
10. A10: Server-Side Request Forgery (SSRF)

https://owasp.org/www-project-top-ten/

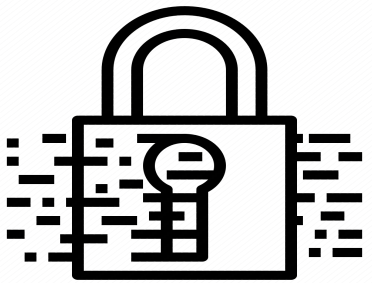


A01:2021 — Нарушение контроля доступа

Контроль доступа обеспечивает соблюдение политики таким образом, чтобы пользователи не могли действовать за пределами своих полномочий. Сбои в работе обычно приводят к несанкционированному раскрытию информации, изменению или уничтожению всех данных или выполнению бизнес-функций за пределами полномочий пользователя

A02: 2021 — сбои в работе криптографии

Прежде всего необходимо определить, какая защита требуется для данных при передаче и хранении. Например, пароли, номера кредитных карт, медицинские записи, личная информация и коммерческая тайна требуют дополнительной защиты, особенно если эти данные подпадают под действие законов о конфиденциальности, таких как Общий регламент ЕС по защите данных (GDPR), или нормативных актов, таких как Стандарт безопасности данных PCI (PCI DSS). Для всех таких данных:



A03:2021 — SQL Injection

Что это такое?

- Вставка SQL-кода в поля формы
- Пример: admin' OR '1'='1

💣 Что может случиться?

- Доступ к чужим данным
- Удаление таблиц

✅ Как защититься:

- Использовать параметризованные запросы
- Проверять и экранировать ввод

A04:2021 – Небезопасный дизайн

Новая категория, появившаяся в 2021 году, посвящена рискам, связанным с проектированием и архитектурными недостатками, и призывает к более широкому использованию моделирования угроз, шаблонов безопасного проектирования и эталонных архитектур.

Небезопасный дизайн — это обширная категория, представляющая различные слабые места, выраженные в виде «отсутствия или неэффективности элементов управления».

Небезопасный дизайн нельзя исправить с помощью идеальной реализации, поскольку по определению необходимые элементы управления безопасностью никогда не создавались для защиты от конкретных атак. Одним из факторов, способствующих созданию небезопасных проектов, является отсутствие анализа бизнес-рисков, присущих разрабатываемому программному обеспечению или системе, и, как следствие, неспособность определить необходимый уровень безопасности.

A05:2021 – Неправильная настройка безопасности

Основные проблемы:

- Отсутствие усиления безопасности или неправильно настроенные разрешения.
- Включение ненужных функций и учетных записей по умолчанию.
- Обработка ошибок с чрезмерной информацией.
- Отключение или ненадежная настройка новейших функций безопасности.
- Небезопасные значения параметров безопасности.
- Устаревшее или уязвимое ПО.
- Отсутствие согласованного процесса настройки безопасности.

A06:2021 — Уязвимые и устаревшие компоненты

Обзор уязвимостей компонентов

- Уязвимости компонентов являются известной проблемой, трудно поддающейся тестированию и оценке рисков.
- Уязвимости не всегда сопоставляются с CWE, поэтому используются эксплойты с весом 5,0 г.
- В список включены CWE, связанные с использованием неподдерживаемых компонентов и уязвимости из прошлых лет.

A07: 2021 — сбои при идентификации и аутентификации

Описание проблем с аутентификацией

- Проблемы с аутентификацией могут возникнуть из-за автоматизированных атак, грубых сил и использования слабых паролей.
- Неэффективные процессы восстановления учетных данных и использование открытых текстовых хранилищ данных также могут быть уязвимостями.
- Отсутствие или неэффективная многофакторная аутентификация и неправильное управление идентификаторами сеанса могут привести к атакам.

A08: 2021 — сбои в работе программного обеспечения и целостности данных

Обзор уязвимостей и факторов воздействия

- Уязвимости связаны с обновлением ПО, критическими данными и конвейерами CI/CD без проверки целостности.
- Общие уязвимости включают CWE-829, CWE-494 и CWE-502.

Сбои в целостности ПО и данных

- Незащищенность от нарушений целостности из-за использования ненадежных источников кода и инфраструктуры.
- Небезопасный конвейер CI/CD может привести к несанкционированному доступу и компрометации системы.
- Автоматическое обновление ПО без должной проверки целостности может привести к распространению вредоносных обновлений.

A09: 2021 — сбои в логировании и мониторинге безопасности

Категория предназначена для выявления, эскалации и реагирования на активные нарушения. Без ведения журнала и мониторинга нарушения невозможно выявить. Недостаточное ведение журнала, обнаружение, мониторинг и активное реагирование происходят в любое время.

Описание категории

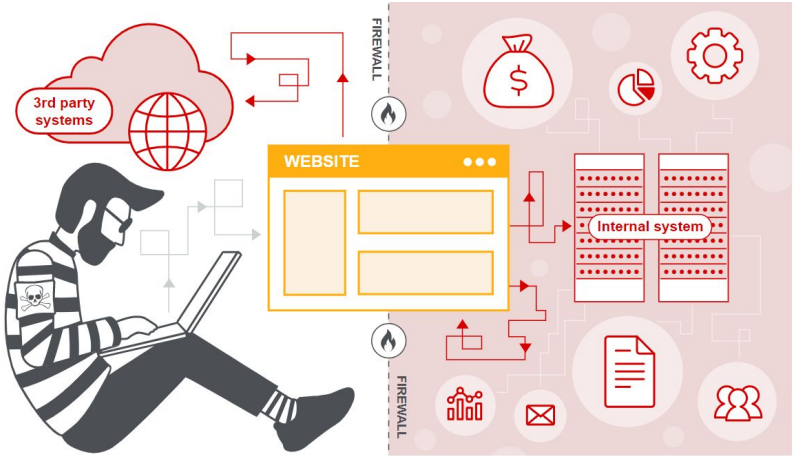
- Помогает обнаруживать и реагировать на активные нарушения.
- Нарушения не регистрируются без ведения журнала и мониторинга.
- Отсутствие предупреждений и ошибок в журнале.
- Локальное хранение журналов без отслеживания подозрительной активности.
- Неэффективные оповещения и процессы реагирования. идентификаторами сеанса могут привести к атакам.

```
- [11/Dec/2022:03:14:49 +0000] "GET /wp-login.php HTTP/1.
 [11/Dec/2022:08:40:59 +0000] "GET /wp-login.php HTTP/1.1
 [11/Dec/2022:11:47:00 +0000] "GET /wp-login.php HTTP/1.1
 [11/Dec/2022:11:47:01 +0000] "GET /wp-login.php HTTP/1.1
[11/Dec/2022:12:49:30 +0000] "GET /wp-login.php HTTP/1.1"
[11/Dec/2022:12:49:30 +0000] "POST /wp-login.php HTTP/1.1
- [11/Dec/2022:13:20:13 +0000] "GET /wp-login.php HTTP/1.
- [11/Dec/2022:13:20:13 +0000] "GET /wp-login.php HTTP/1.
 [11/Dec/2022:13:40:17 +0000] "GET /wp-login.php HTTP/1.1
 [11/Dec/2022:13:40:17 +0000] "GET /wp-login.php HTTP/1.1
 [11/Dec/2022:13:40:17 +0000] "GET / HTTP/1.1" 302 5262 "
- [11/Dec/2022:14:30:14 +0000] "GET /wp-login.php HTTP/1.
```

A10:2021 — Подделка запроса на стороне сервера SSRF

Описание ошибок SSRF

- Ошибки SSRF возникают при получении удаленных ресурсов без проверки URL
- Злоумышленник может заставить приложение отправить запрос в неожиданное место
- Частота возникновения SSRF увеличивается из-за удобства функций веб-приложений
- Тяжесть SSRF усиливается из-за облачных сервисов и сложности архитектур



Итоги урока

- Познакомились с основными уязвимостями для веб-приложений
- Разобрались как их эксплуатируют
- Узнали как от них защититься